



ESCUELA COLOMBIANA DE INGENIERÍA JULIO GARAVITO

SEGURIDAD Y PRIVACIDAD DE TI

INTRODUCCIÓN A KERALTY (CASO ESTUDIO)

ENFOCADO EN

Conceptos fundamentales de seguridad

**ANDERSSON DAVID SÁNCHEZ MÉNDEZ
CRISTIAN SANTIAGO PEDRAZA RODRÍGUEZ
LAURA VALENTINA GUTIÉRREZ RICO**

PROFESOR:

JAVIER IVAN TOQUICA BARRERA

Lugar: Bogotá

Fecha: Febrero 06/2026



INTRODUCCIÓN A KERALTY (CASO ESTUDIO)

Estudiante: Andersson David Sánchez Méndez

Estudiante: Cristian Santiago Pedraza Rodríguez

Estudiante: Laura Valentina Gutiérrez Rico

Enfocado en: Conceptos fundamentales de seguridad

Fecha: Febrero 06, 2026

1. ¿Qué es grupo Keralty?

Grupo Keralty es un conglomerado empresarial multinacional del sector salud, con presencia en varios países de América y Europa. En Colombia, es ampliamente conocido por ser el grupo controlador de Sanitas, así como de otras compañías relacionadas con la prestación de servicios médicos, planes de salud, clínicas, laboratorios y aseguradoras.

En Colombia, Keralty atiende a **millones de afiliados**, gestiona información altamente sensible (datos personales y datos de salud) y opera sistemas críticos para la atención médica, autorizaciones, historia clínica, facturación y continuidad asistencial.

Por su naturaleza, el grupo está sujeto a **altos niveles de regulación**, incluyendo normativas de protección de datos personales, continuidad del servicio y seguridad de la información.

2. Contexto del Incidente

Grupo Keralty es un conglomerado del sector salud con alta presencia en Colombia, propietario de EPS Sanitas y **Clínicas Colsanitas**.

Estas organizaciones prestan servicios de salud a **millones de afiliados** y gestionan información altamente sensible, incluyendo **datos personales y datos de salud**, por lo que sus sistemas tecnológicos son críticos para la continuidad del servicio y el cumplimiento regulatorio.

3. ¿Qué sucedió?

A finales de noviembre de 2022 (entre el 28 y 29 de noviembre), Grupo Keralty sufrió un ataque de ransomware que comprometió parte de su infraestructura tecnológica en Colombia.

Como consecuencia del incidente:

- Se interrumpieron canales digitales, agendamiento de citas y sistemas de atención.
- La afectación se extendió durante varias semanas, impactando a cerca de 5,5 millones de usuarios.
- Un grupo cibercriminal, identificado públicamente como RansomHouse, afirmó haber sustraído información interna y amenazó con su divulgación como mecanismo de extorsión.
- La organización no realizó pagos y activó planes de contingencia para restablecer los servicios.

Debido al impacto en la atención médica, la Defensoría del Pueblo intervino, requiriendo la restauración de los servicios digitales y la adopción de medidas para proteger los datos personales y garantizar el derecho fundamental a la salud.

4. Cuestionario

1. **Elabore una lista paso a paso los eventos que permitieron la materialización del ataque y las acciones de respuesta implementadas por Grupo Keralty / Sanitas, desde la detección inicial hasta la contención del impacto.**

Este ataque no se originó por un error técnico, fue una secuencia de varios sucesos (fallos, ejecuciones, reacciones, etc.) que terminaron en una crisis de servicios críticos y pérdidas considerables. Los eventos importantes fueron:

a) Inicio del incidente (27 – 28 de noviembre de 2022):

- Acceso no autorizado en la infraestructura tecnológica del grupo Keralty (propietario de EPS Sanitas y Colsanitas), materializado mediante la introducción de ransomware, considerado como una amenaza que bloquea sistemas y/o exfiltra datos para pedir un pago o extorsión.

b) Notificación y reconocimiento interno:

- Sistemas empiezan a fallar, como, plataformas de atención digital, agendamiento de citas, portales de usuarios y acceso remoto. La empresa informa públicamente que hay un ciberataque.

c) Identificación del grupo criminal:

- Grupo cibercriminal *RansomHouse* reclama la autoría del ataque, parte de la información sustraída queda pública, para intentar usarla como extorsión.

d) Interrupción de servicios y comunicación con usuarios:

- Atención digital colapsa durante varios días; los usuarios no pueden agendar citas ni consultar resultados, por tanto, Keralty emite comunicaciones, se da a la necesidad de priorizar servicios presenciales y habilita canales alternativos mientras trabaja para restaurar servicios.

e) Activación de planes de contingencia:

- Equipo de tecnología y soporte de Keralty activa protocolos de continuidad, incluyendo trabajo 24/7, respaldo de sistemas críticos, escalamiento del incidente y monitoreo constante para contener la propagación.

f) Solicitud de intervención estatal:

- Defensoría del Pueblo interviene, exige restaurar servicios digitales de inmediato y proteger el derecho fundamental a la salud de los afiliados afectando la atención médica.

g) Recuperación y restauración progresiva:

- Cuando se identifican y remueven los vectores de ataque, los servicios se van restableciendo y Keralty sigue fortaleciendo sus controles de seguridad.

2. **Explique ampliamente, ¿Cuáles fueron los atributos de la triada de seguridad (CIA) afectados durante el ataque?**

La triada CIA (Confidencialidad, Integridad y Disponibilidad) es la base de la seguridad de la información. En este incidente, los tres componentes fueron impactados, pero desde diferentes perspectivas:

- **Confidencialidad:**
 - a) Durante el ataque los ciberdelincuentes accedieron, suponiendo que también copiaron datos internos, incluyendo información corporativa, estados financieros y al parecer partes de información personal de usuarios, colaboradores y proveedores.
 - b) La publicación de datos clasificados en canales públicos (canales de *RansomHouse*) evidencia una violación directa a la confidencialidad de la información almacenada en los sistemas de Keralty.
- **Integridad:**
 - a) Aunque el objetivo principal fue la interrupción y el robo de información, el adversario también comprometió la integridad al manipular sistemas o impedir que los datos continuaran siendo confiables y consistentes durante la operación del ataque.
 - b) La interrupción forzó a los equipos internos a operar fuera de los canales digitales que utilizaban con normalidad, dejando la integridad de algunos procesos críticos sin poder solucionarlos a tiempo.
- **Disponibilidad:**
 - a) Este fue el atributo más visiblemente afectado.
 - b) La no disponibilidad de canales digitales, sistemas de agendamiento de citas y consultas provocó la imposibilidad de acceder a servicios, citas, autorizaciones médicas y resultados.
 - c) Afectó tanto procesos administrativos, como la continuidad en la atención médica de millones de afiliados.

3. Explique ampliamente, ¿este caso deriva en una afectación a la privacidad de datos?

Sí. Este caso no solo es un incidente técnico, sino una afectación directa a la privacidad de datos personales:

- a) Los atacantes se atribuyeron del robo de archivos que contenían cédulas, direcciones, teléfonos e incluso información de afiliados y proveedores.
- b) La Defensoría del Pueblo exigió a Keralty informar si los datos personales y de salud de los usuarios se vieron comprometidos, ya que esto implicaría una vulneración de derechos fundamentales (derecho a la privacidad y protección de datos personales).
- c) La exposición de este tipo de datos no autorizada es un ejemplo claro con alto impacto sobre la privacidad, porque como generar problema de disponibilidad, también puede desencadenar riesgos como suplantación de identidad, fraudes y daños reputacionales.

4. ¿El incidente se puede catalogar en el universo de la seguridad de la información o la Ciberseguridad?

Este incidente pertenece al universo de la ciberseguridad, que es un subconjunto especializado de la seguridad de la información:

- Seguridad de la información abarca políticas, procedimientos y controles para proteger la confidencialidad, integridad y disponibilidad de la información en todos sus formatos (físico, digital y organizacional).
- Ciberseguridad se enfoca específicamente en la protección de sistemas, redes y datos digitales frente a amenazas y ataques provenientes del ciberespacio.

Este ataque fue realizado a través de vectores digitales (ransomware, acceso no autorizado y exfiltración de datos), por lo que está claramente dentro del

ámbito de la ciberseguridad. Pero también tuvo impactos sobre la seguridad de la información en general (confidencialidad de datos personales y continuidad de procesos).

5. Investigue sobre el grupo cibercriminal a quién se adjudicó el ataque, origen, modos de operación, países donde ha materializado ataques, otros ataques relevantes.

RansomHouse es un grupo cibercriminal especializado en ransomware y *double extortion* (doble extorsión). Su perfil se puede describir así:

- **Origen y naturaleza:**
 - a) Surgió alrededor de finales de 2021 como un operador de ransomware-as-a-service (RaaS), un modelo que alquila o provee herramientas de ataque a terceros.
 - b) Originalmente operaba principalmente como banda que robaba datos para extorsionar, y con el tiempo evolucionó a técnicas más complejas que combinan cifrado y *exfiltración*.
- **Modus operandi:**
 - a) Acceso inicial: Mediante explotación de vulnerabilidades, phishing dirigido o puntos expuestos en la red.
 - b) Movimiento lateral y exfiltración: Obtienen acceso elevado dentro de la red para recopilar datos sensibles.
 - c) Ransomware & doble extorsión: Cifran sistemas o retienen datos, y luego exigen rescate bajo amenaza de hacer públicos esos datos.
 - d) Mantienen presencia en la Dark Web para publicar muestras o listas de víctimas si no reciben pago.
- **Países y sectores atacados:**
 - a) Colombia: Ataque al grupo Keralty / EPS Sanitas.
 - b) España: Universidades y clínicas, como la Universidad de Paris-Saclay (publicación de datos personales de candidatos).
 - c) Italia: Publicación de 2.1 TB de datos de ocho municipios.
 - d) Malta: Ataque a una empresa constructora con amenaza de filtración de datos.
 - e) Otras regiones y empresas han aparecido en listados de víctimas (incluyendo sectores financieros y manufactura).

REFERENCIAS

- Infobae. (2023). *Ciberataque a Sanitas: hackers revelaron más información clasificada de la EPS*. Retrieved from <https://www.infobae.com/colombia/2023/03/14/ciberataque-a-sanitas-hackers-revelaron-mas-informacion-clasificada-de-la-eps/> (Reference for Parts 1, 2 and 3: Incident timeline, impact, CIA triad and data exposure).
- Defensoría del Pueblo. (2022). *Defensoría requirió a Keralty (EPS Sanitas y Colsanitas) para que restaure sus servicios digitales y garantice el derecho fundamental a la salud*. Retrieved from <https://www.defensoria.gov.co> (Reference for Parts 1 and 3: Institutional response, users' rights, privacy and health impact).
- Fortinet. (2023). *Threat Actor Profile: RansomHouse Ransomware*. FortiGuard Labs. Retrieved from <https://fortiguard.fortinet.com/threat-actor/6250/ransomhouse-ransomware> (Reference for Part 5: Threat actor overview, ransomware and double extortion model).
- Acronis. (2023). *RansomHouse breaches multiple organizations and publishes terabytes of stolen data*. Acronis Cyber Protection Blog. Retrieved from <https://www.acronis.com/en-eu/tru/posts/> (Reference for Part 5: International attacks and data-leak strategy).
- CSIDB – Cyber Security Incident Database. (n.d.). *RansomHouse threat actor profile*. Retrieved from <https://www.csidb.net/csidb/actors/> (Reference for Part 5: Historical attacks, sectors affected and operational behavior).
- DPL News. (2022). *Colombia: Sanitas restablece su oficina virtual tras ciberataque*. Retrieved from <https://dplnews.com> (Reference for Part 1: Service disruption, recovery process and continuity actions).
- National Institute of Standards and Technology (NIST). (2018). *Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1*. Retrieved from <https://www.nist.gov/cyberframework> (Reference for Parts 1 and 4: Incident response lifecycle and cybersecurity scope).
- ISO/IEC. (2012). *ISO/IEC 27032: Guidelines for Cybersecurity*. International Organization for Standardization. (Reference for Part 4: Difference between Information Security and Cybersecurity).